# WEB APPLICATION PENETRATION TEST REPORT

**Project: CloudExify Cybersecurity Month 2 — Project 3**

**Target Application: DVWA (Damn Vulnerable Web Application)**

**Target URL: http://192.168.XXX.XXX /dvwa/**

**Submitted by : Ahil Arslan**

**Classification: Confidential**

## EXECUTIVE SUMMARY

This security assessment was conducted on the DVWA web application to identify vulnerabilities based on OWASP Top 10 standards. Multiple critical vulnerabilities were successfully identified and exploited, including SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), File Upload vulnerabilities, and Authentication Bypass.

**Total Vulnerabilities Found: 5**
**Critical: 3**
**High: 2**

## TESTING ENVIRONMENT

**Tools Used:**

Burp Suite Community Edition
Firefox ESR Browser
DVWA Application

**Target Details:**

Application: DVWA v1.0.7
Security Level: Low
IP Address: 192.168.149.133

## 1: SQL INJECTION

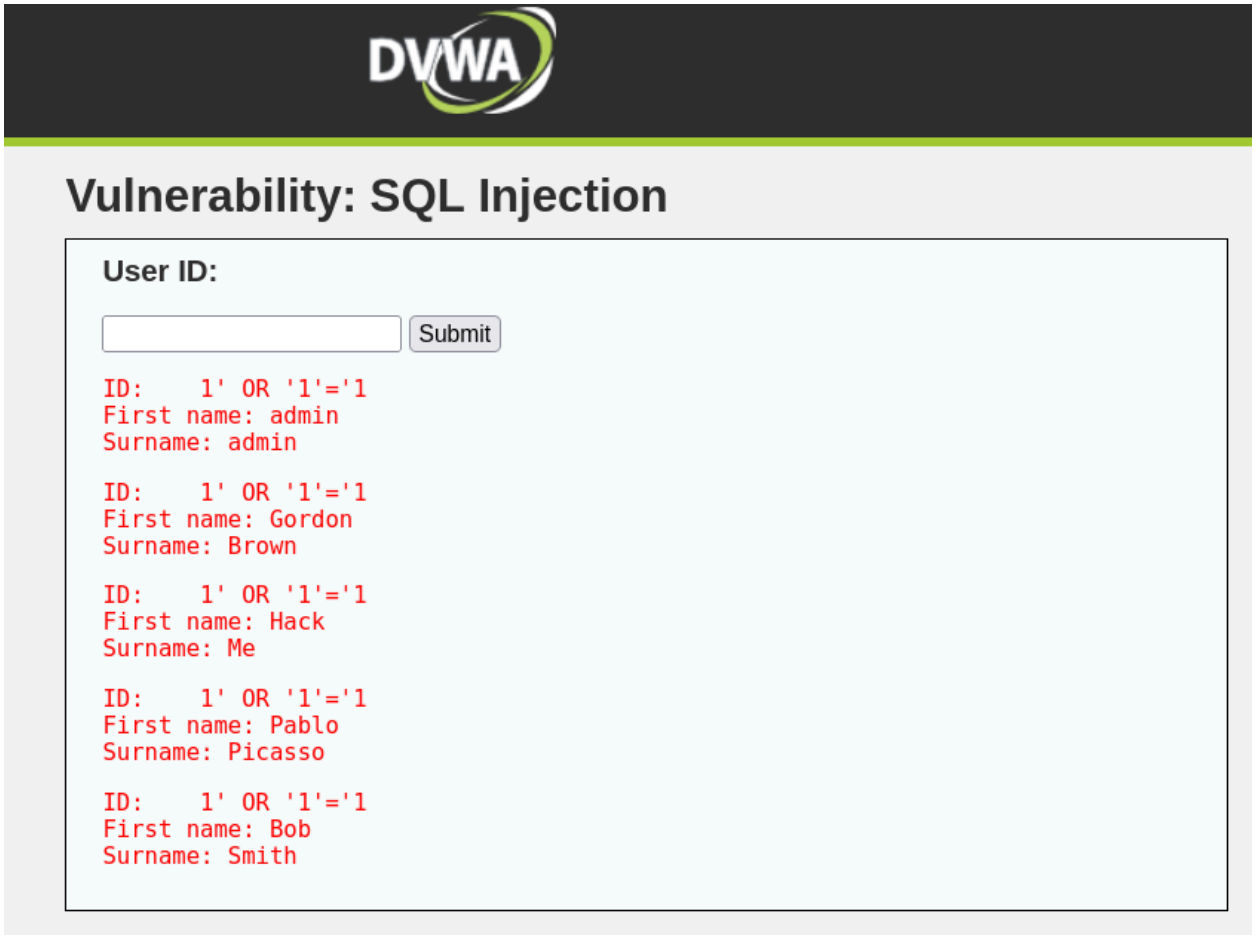
**Severity: Critical**

**Description:**
The application is vulnerable to SQL injection attacks where user input is not properly sanitized before being included in database queries.

**Payload Used:**
1' OR '1'='1

**Impact**:

Unauthorized access to database
Extraction of sensitive user information
Authentication bypass




## 2: CROSS-SITE SCRIPTING (XSS)

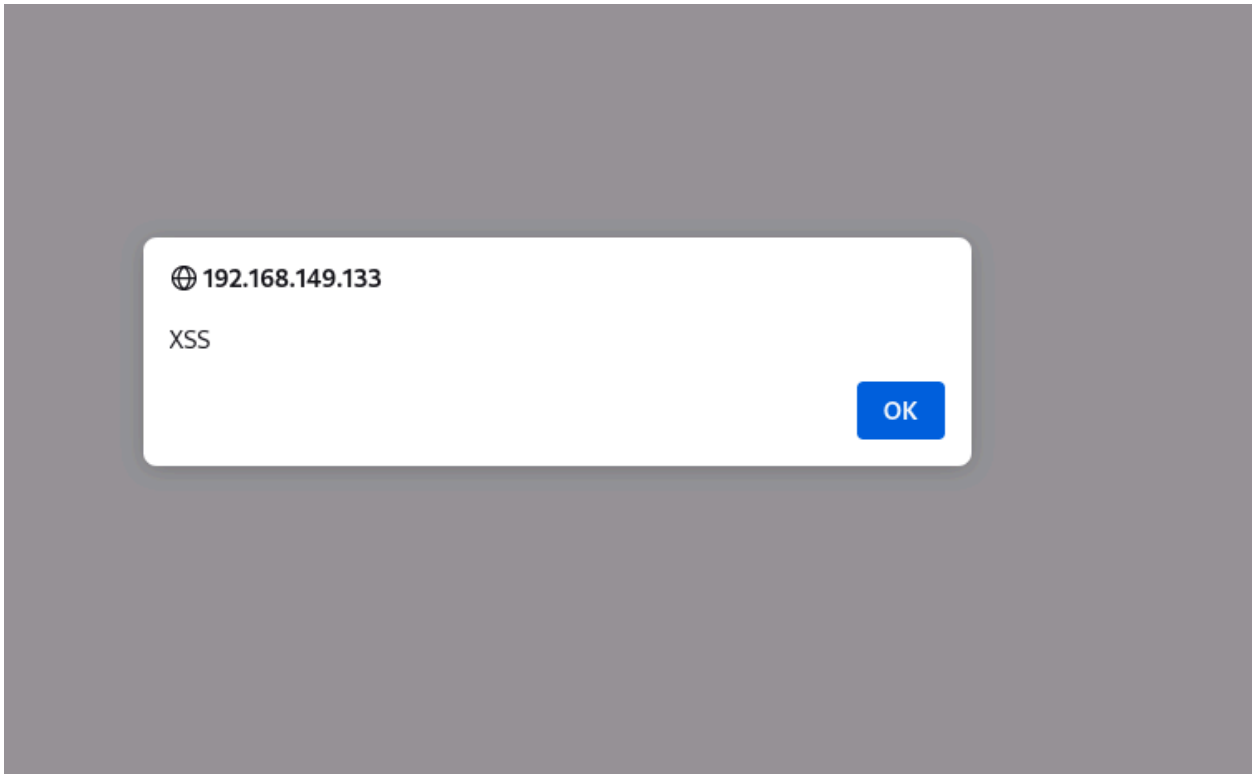
**Severity: High**

**Description**:
The application reflects user input without proper encoding, allowing execution of malicious JavaScript in the browser.

**Payload Used:**
<script>alert('XSS')</script>

**Impact**:

Session hijacking
Credential theft
Malicious code execution
Evidence:




## 3: CROSS-SITE REQUEST FORGERY (CSRF)

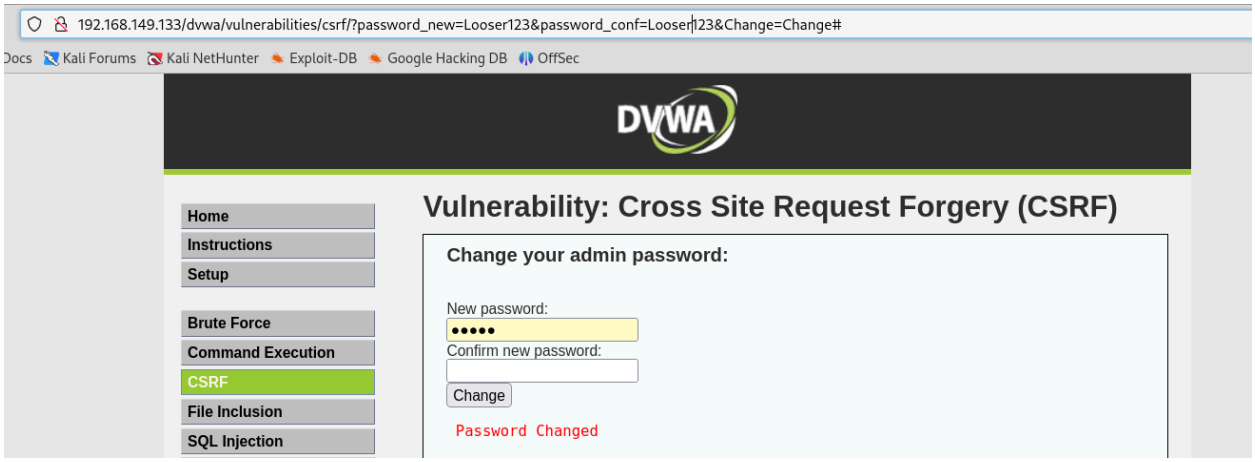
**Severity: High**

**Description:**
The application processes state-changing requests without anti-CSRF tokens, allowing unauthorized actions to be performed.

Test Performed:
Changed admin password through direct URL manipulation.

**Impact:**

Unauthorized password changes
Account takeover
Unauthorized actions on behalf of users




## 4: FILE UPLOAD VULNERABILITY

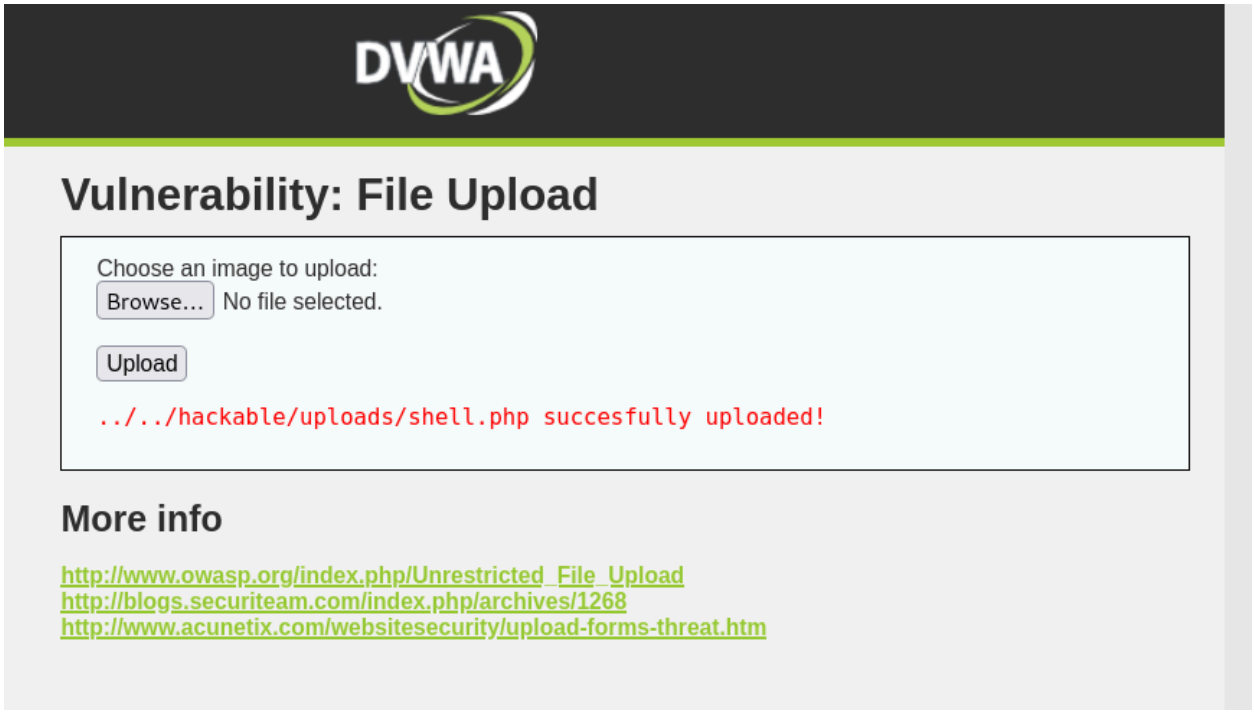
**Severity: Critical**

**Description:**

The application allows upload of executable PHP files without proper validation, leading to remote code execution.

**File Uploaded:**

shell.php
Impact:
Remote code execution
Complete server compromise
Malware hosting




## 5: AUTHENTICATION BYPASS

**Severity: Critical**

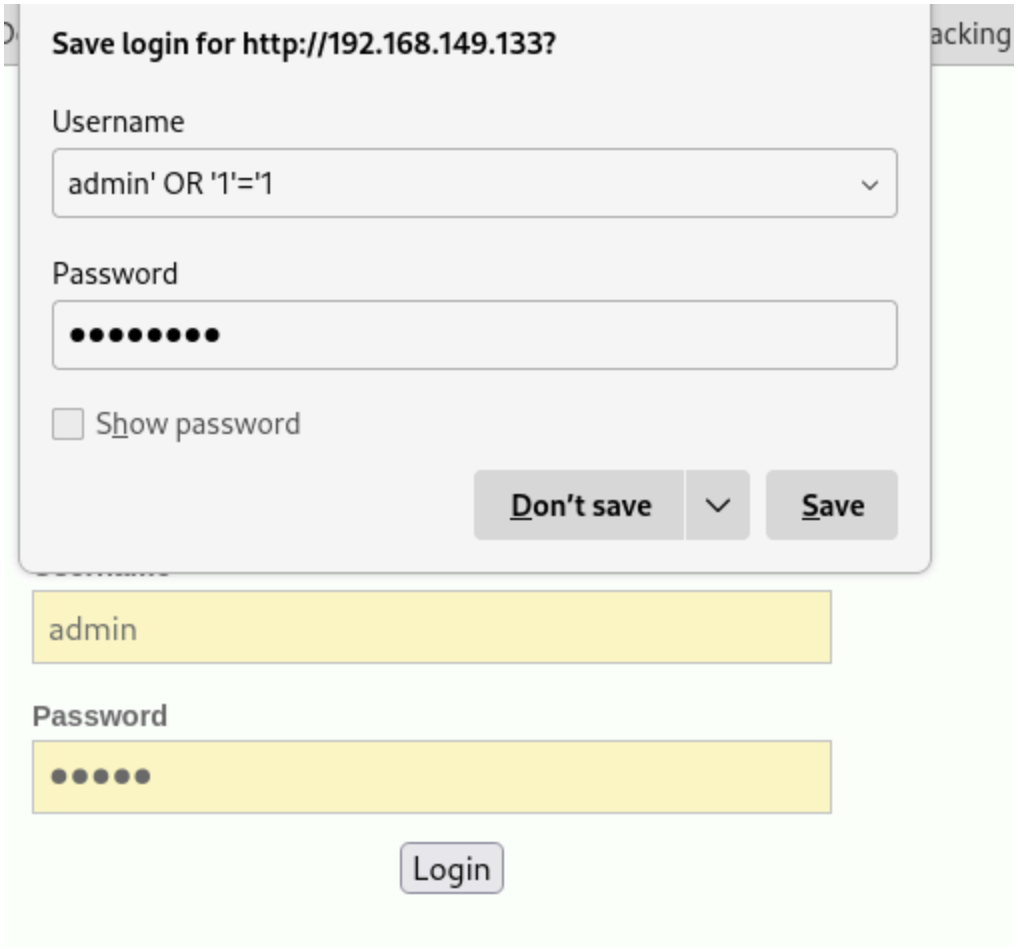
**Description:**
The login mechanism is vulnerable to SQL injection, allowing authentication bypass without valid credentials.

**Payload Used:**

Username: admin' OR '1'='1
Password: anything

**Impact**:

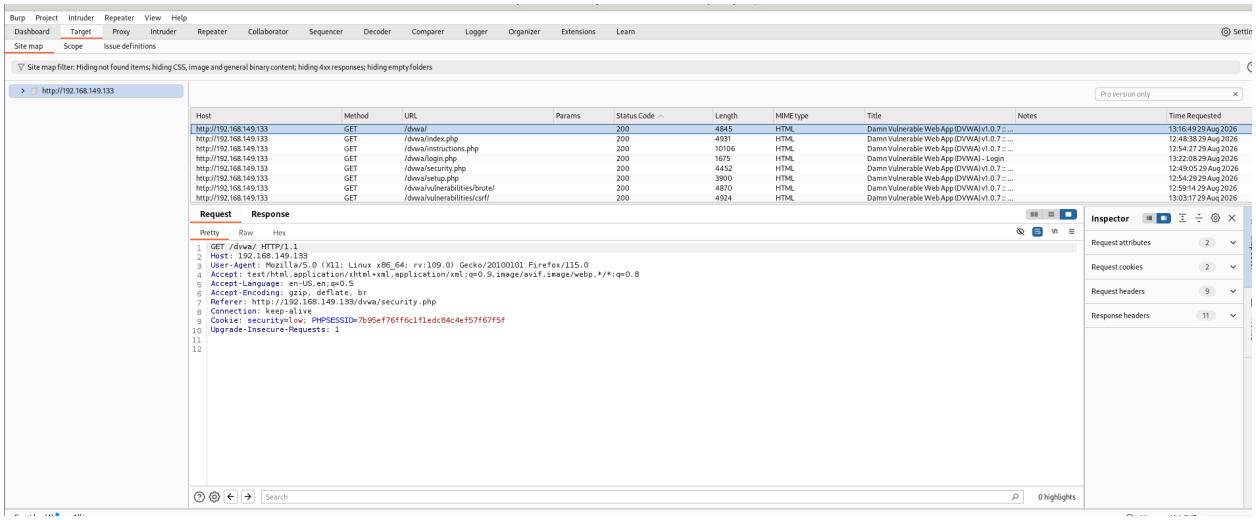
Unauthorized access to user accounts
Complete authentication bypass
Administrative access




## BURP SUITE ANALYSIS

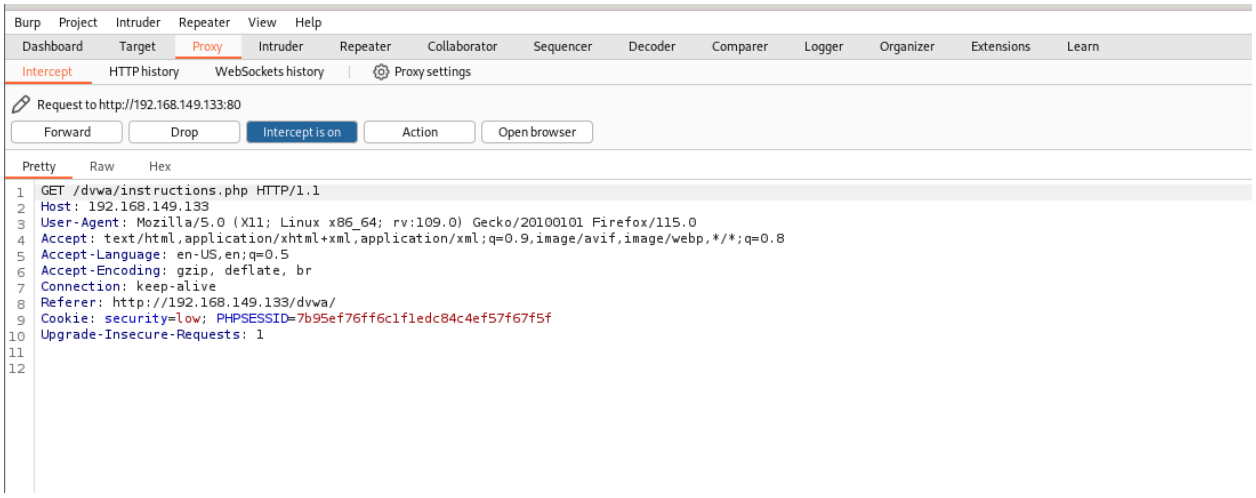
### Proxy Interception

Burp Suite successfully intercepted all HTTP traffic between the browser and the DVWA application, allowing for request inspection and manipulation.



## Application Mapping

Burp Suite Target module mapped all application endpoints and discovered the complete application structure.



## DVWA APPLICATION OVERVIEW

### Main Dashboard:




## REMEDIATION RECOMMENDATIONS

### Immediate Actions Required:

**SQL Injection:**
Use parameterized queries
Implement input validation

**XSS**:
Escape all user input
Implement Content Security Policy

**CSRF:**
Add anti-CSRF tokens to all forms
Verify session token

**File Upload:**
Validate file extensions
Store files outside web root
Disable PHP execution in upload folder

**Authentication:**

Use prepared statements
Implement account lockout
Use strong password hashing

## CONCLUSION

The DVWA application contains multiple critical vulnerabilities that would allow an attacker to completely compromise the system. Immediate remediation is required before any production deployment.

Overall Risk Rating: CRITICAL